

AI Vendor Risk Assessment Questionnaire

Vendor name: _____

Product/service under review: _____

Assessed by: _____

Date: _____

Business owner / requestor: _____

Decision: ☐ Approved ☐ Approved with conditions ☐ Rejected ☐ More information needed

Use this questionnaire when an AI tool, vendor, SaaS AI feature, or AI-enabled workflow needs more than the lite checklist. Have the requesting business owner complete Sections 1-3. Complete Sections 4-10 from vendor documentation, security portals, trust centers, contracts, and vendor answers.

Section 1 - What the tool is for

1.1 In one sentence, what problem does this tool solve for us?

1.2 Who on the team will use it? Include roles and approximate count.

1.3 Is there an existing approved tool that already covers this use case? If yes, why is it not sufficient?

1.4 What business outcome are we expecting? Examples: hours saved per week, faster response times, reduced error rate, better routing, improved documentation.

1.5 Who will own this tool after approval?

Section 2 - What data goes into it

Check all that apply.

- ☐ Only information already public on our website or public materials
- ☐ Internal business information
- ☐ Customer names, emails, phone numbers, addresses
- ☐ Customer account data, purchase history, usage data, or support history
- ☐ Employee, contractor, volunteer, student, or applicant personal information
- ☐ Health information
- ☐ Financial information or payment information
- ☐ Children's data
- ☐ Biometric information

- ☐ Source code, model files, product roadmaps, or other intellectual property
- ☐ Third-party data received under NDA or contract
- ☐ Legal, privileged, dispute-related, or regulated information
- ☐ Government ID numbers
- ☐ Other: _____

2.1 Estimated records, prompts, files, calls, queries, or transactions per month:

2.2 Will files, recordings, images, audio, video, logs, or database exports be uploaded?

- ☐ No
- ☐ Yes - describe:

2.3 What data should be prohibited from this tool even if approved?

Section 3 - How it will be used

3.1 Will this tool make or meaningfully inform decisions about people, including hiring, firing, lending, pricing, housing, insurance, benefits, education, healthcare, legal services, public services, safety, eligibility, or access to important opportunities?

- ☐ No
- ☐ Yes - describe:

3.2 Will the output be shown directly to customers, clients, patients, students, applicants, employees, or the public?

- ☐ No
- ☐ Yes - describe:

3.3 Will this tool be connected to other company systems such as email, CRM, databases, file storage, internal chat, code repositories, or production systems?

- ☐ No
- ☐ Yes - list integrations:

3.4 Could a failure of this tool harm a customer, employee, applicant, student, patient, client, or third party?

- ☐ No meaningful harm likely
- ☐ Minor inconvenience only
- ☐ Could affect livelihood, health, safety, legal rights, finances, eligibility, or access to important services
- ☐ Unknown

3.5 What human review will happen before output is used externally or relied on?

Section 4 - Vendor and product basics

4.1 Legal entity name and country of headquarters:

4.2 Years in operation and year the AI product or feature launched:

4.3 Product status:

- ☐ Generally available
- ☐ Beta
- ☐ Pilot
- ☐ Custom / private deployment
- ☐ Unknown

4.4 Is the product built on another provider's model or API? If yes, name the underlying provider and model family if known.

4.5 Where is the product hosted? Include cloud provider and region if known.

4.6 Does the vendor maintain a trust center, security portal, or standard questionnaire package?

Section 5 - Model training and evaluation

5.1 Was the model trained on publicly available internet data?

5.2 Was licensed, purchased, customer, proprietary, or third-party data used for training? If yes, describe the rights held.

5.3 Are customer inputs, outputs, files, prompts, or usage logs used to train or improve models?

- ☐ Never
- ☐ Only if customer opts in
- ☐ Yes by default, opt-out available
- ☐ Yes by default, no opt-out
- ☐ Unknown

Evidence or contract citation:

5.4 Has the vendor tested for bias, unfairness, harmful output, or safety issues relevant to our use case? Attach or link summaries.

5.5 Has the vendor red-teamed or externally evaluated the AI system? Attach or link summaries.

Section 6 - Data handling

6.1 What customer data is stored by the vendor?

6.2 Data retention: how long are inputs, outputs, logs, files, recordings, and metadata stored?

6.3 Deletion: can we delete data on request? What is the timeline?

6.4 Geographic location of data at rest and in process:

6.5 Subprocessors and partners that may access our data:

6.6 Cross-border transfer terms, if data leaves a jurisdiction with transfer requirements:

6.7 Can data access, retention, training, logging, or sharing settings be configured by customer admins?

Section 7 - Security

7.1 Current security certifications or reports:

- ☐ SOC 2 Type II
- ☐ ISO 27001
- ☐ HIPAA attestation or BAA support
- ☐ PCI DSS
- ☐ FedRAMP
- ☐ Penetration test summary
- ☐ Other: _____

7.2 Encryption in transit and at rest; key management approach:

7.3 Authentication and access controls: SSO, MFA, role-based access, admin roles, least privilege.

7.4 Logging and audit trail: what is logged, who can access it, and how long logs are retained.

7.5 Security incidents in the last 24 months and remediation status:

7.6 Vulnerability management, penetration testing, and security review cadence:

Section 8 - AI-specific risks and controls

8.1 How does the vendor detect and reduce prompt injection, jailbreaks, abuse, or unsafe use?

8.2 How are outputs checked for harmful, illegal, infringing, biased, inaccurate, or unsafe content?

8.3 What hallucination, error, or accuracy information is available for use cases like ours?

8.4 Can we configure guardrails such as blocked topics, data loss prevention, refusal behavior, review workflows, or role permissions?

8.5 Is human review available or recommended before output is used externally or relied on?

8.6 Are model upgrades, feature changes, deprecations, or material behavior changes announced in advance? What notice is provided?

Section 9 - Legal, regulatory, and contractual

9.1 What laws, standards, or frameworks does the vendor claim to support or align with? Attach evidence rather than relying on marketing claims.

9.2 Who owns customer inputs? Who owns outputs?

9.3 Does the vendor provide IP infringement indemnity for outputs? Note any exclusions.

9.4 Liability caps and exclusions in the standard contract:

9.5 Data processing or sector-specific agreements available:

- ☐ Data Processing Agreement
- ☐ Business Associate Agreement, if health data is involved
- ☐ Standard Contractual Clauses or equivalent transfer terms, if relevant
- ☐ Student data agreement, if relevant
- ☐ Other: _____
- ☐ Not applicable

9.6 Will the vendor support customer disclosure, audit, recordkeeping, or regulator/customer inquiry needs?

Section 10 - Exit and continuity

10.1 How do we export our data, outputs, settings, or logs if we leave?

10.2 What happens to our data after termination, and on what timeline?

10.3 Business continuity: uptime, SLA, support, disaster recovery, and incident response commitments.

10.4 What if the vendor is acquired, shuts down, materially changes the product, or deprecates the feature?

Reviewer notes

Decision

Risk tier: ☐ Low ☐ Medium ☐ High ☐ Unacceptable

Decision: ☐ Approved ☐ Approved with conditions ☐ Rejected ☐ More information needed

Approved scope:

Conditions if approved:

Follow-up actions:

Next review date: _____

Approved by: _____ (name, title, date)

Disclaimer

This document is a template for educational and informational purposes only. It is not legal advice and does not create an attorney-client relationship. Consult qualified counsel and appropriate privacy, security, procurement, HR, and technical reviewers before relying on this questionnaire for legal compliance, regulated use cases, sensitive data use, or vendor approval decisions.